

CVEs más relevantes de la semana

Del 05/09/2026 al 12/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-86060

Descripción: RouterOS contains an argument-handling flaw in the SSH login path involving usernames that begin with a prohibited character, allowing for the trusted RouterOS policy mask to be changed, leading to privilege escalation. Exploitation requires an unauthenticated SSH session to reach the RouterOS login helper. This issue was fixed in versions: 6.49.21 (Long-term), 7.23.4 (Long-term) and 7.24.2 (Sta...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-88

Tecnología: No especificado

Publicado el: 2026-09-05



CVE-2026-86218

Descripción: N-central is vulnerable to a pre-auth remote code execution This issue affects N-central: before 2026.3.1.14.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-96

Tecnología: No especificado

Publicado el: 2026-09-06



CVE-2026-86419

Descripción: Affected versions of MISP contain insufficient validation of server-side outbound HTTP destinations in feed retrieval and TAXII discovery functionality.

In feed processing, redirects were followed without validating the redirect scheme or destination. The original request headers were reused across redirect hops, meaning authentication headers or API credentials configured for a feed could be...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:H

Tipo: CWE-200

Tecnología: No especificado

Publicado el: 2026-09-07



CVE-2026-80129

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-09-07



CVE-2026-80131

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-09-07



CVE-2026-80164

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to unauthorized access.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-09-07



CVE-2026-86543

Descripción: knowns versions before 0.30.0 serve the management API without authentication on all network interfaces by default, with no password required on fresh installations. Attackers can access the unauthenticated /api/tunnel/start endpoint to provision a public tunnel and republish the API at a publicly accessible address.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-09-07



CVE-2026-77089

Descripción: Command Center API contained an authentication bypass issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Command Center.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-09-08



CVE-2026-77092

Descripción: Content Extractor contained a deserialization of untrusted data issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update Content Extractor.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-09-08



CVE-2026-77098

Descripción: Private Metrics Server contained an SQL injection condition affecting database operations. Software customers upgrade to resolved maintenance release. Update Private Metrics Server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-08



CVE-2026-73309

Descripción: XenForo before 2.3.13 contains an authentication bypass vulnerability in the OAuth2 token endpoint that allows unauthenticated attackers to obtain valid token pairs by submitting empty values for client_secret and code_verifier parameters. Attackers can exploit PHP truthy evaluation logic, which treats empty strings as false and skips client secret validation and PKCE code verifier validation, ...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-697

Tecnología: No especificado

Publicado el: 2026-09-08



CVE-2026-61516

Descripción: Netis NX10 firmware V4.0.1.5808 and V3.0.0.4142 contain an information disclosure vulnerability that allows unauthenticated attackers to retrieve the administrator password by sending a request to the sysinfo action in the web management interface without a valid session. Attackers can replay the exposed credential against the login handler to establish a fully authenticated administrator sessi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-522

Tecnología: No especificado

Publicado el: 2026-09-08



CVE-2026-87534

Descripción: Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-87544

Descripción: Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-21095

Descripción: Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-21096

Descripción: Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-79941

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-79689

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-87929

Descripción: MaxSite CMS through 109.6 ships with a hardcoded session encryption key in application/config/config.php that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious ci_session cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication che...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-9163

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection.

This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-10



CVE-2026-80424

Descripción: IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-09-10



CVE-2026-89009

Descripción: WAVLINK WN535M1 and WN535M3 routers running firmware prior to M35M1_V250922 contain an unauthenticated arbitrary file write vulnerability that allows remote attackers to overwrite any file on the device by sending a crafted payload to the sync_server daemon on TCP port 13136. The daemon, which runs as root and requires no authentication, accepts a 100-byte filename field in its protocol header ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-36

Tecnología: No especificado

Publicado el: 2026-09-11



CVE-2026-78006

Descripción: The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the `is_safe_widget_instance` function. This is due to insufficient protection in `is_safe_widget_instance`, which can be bypassed because PHP fires magic methods during its pre-parse, combined with `enable_rendering_widget_copied()` forging a valid `wp_hash` integrity at...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-09-12



CVE-2026-78159

Descripción: The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_array(). This makes i...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-12



Resumen del Reporte

CVEs analizados: 24

Promedio CVSS: 8.90

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

